

Plan van Aanpak

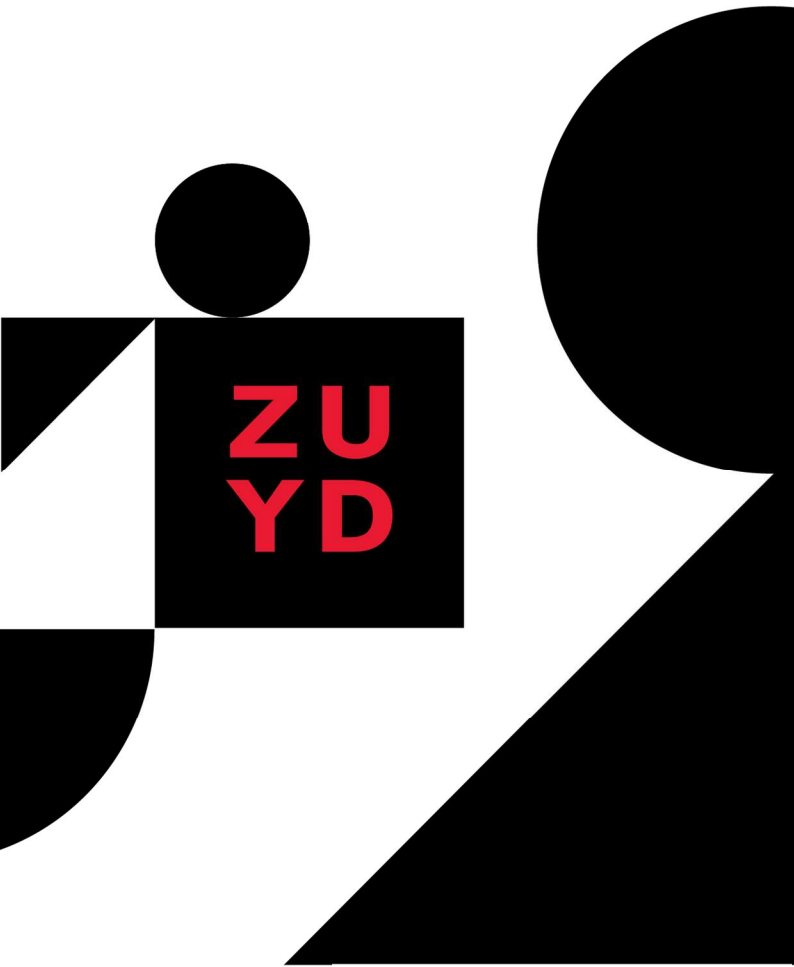
Casus ZKOO

HBO-ICT Zuyd Hogeschool

Module Data Protection Leerjaar 2 blok 1

ZKOO 3

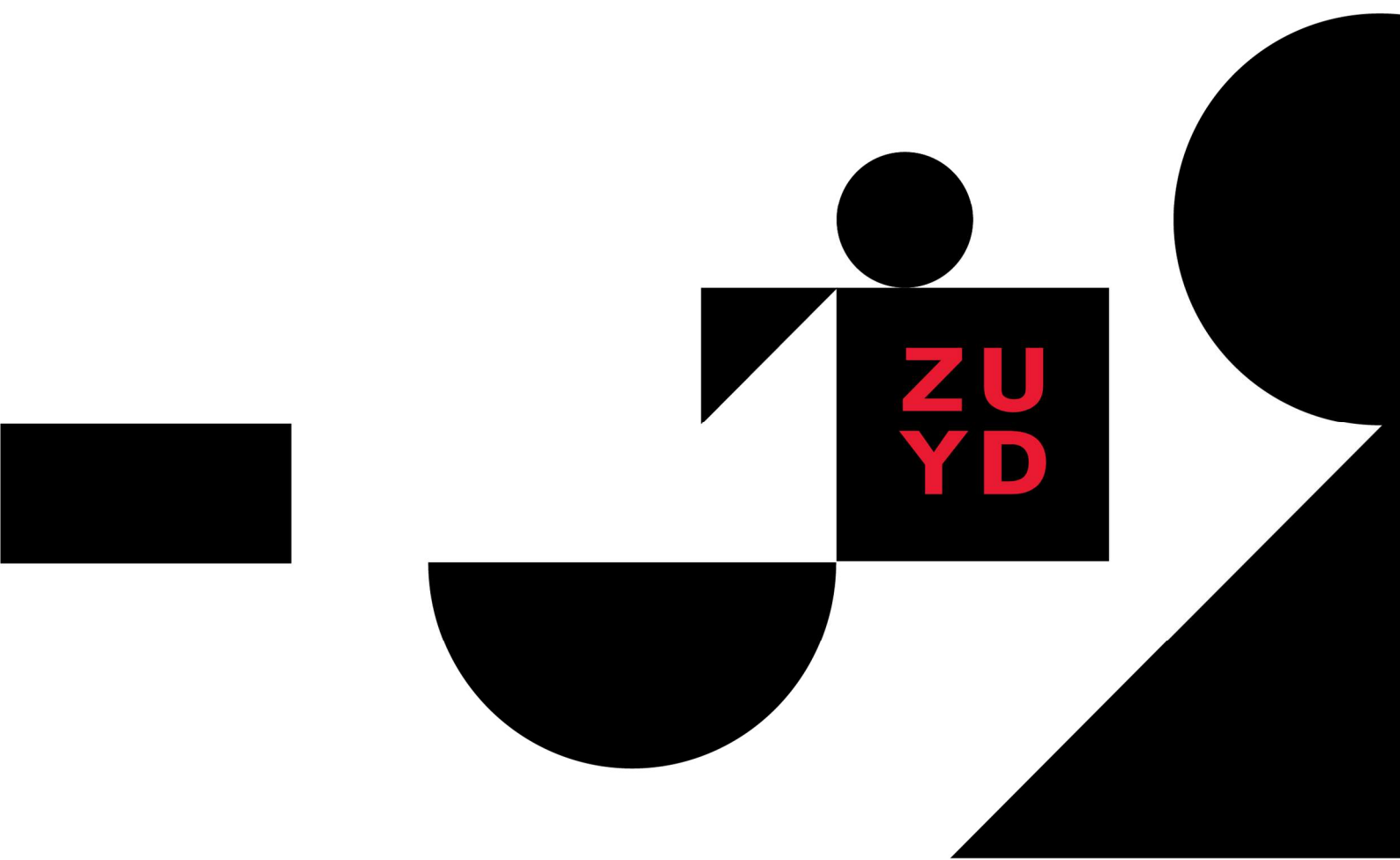
2505493	Arman, Maiwand
2605402	Carley, Chris
2406365	Koeman, Nathalie
2062550	Weerts, Connor

The logo is a stylized representation of a person. It features a solid black circle for the head, a black square for the torso, and a black triangle for the arm. The word 'ZUYD' is written in red, bold, sans-serif capital letters across the chest area of the square.

**ZU
YD**

Inhoud

1. Achtergronden	1
2. Doelstelling	3
3. Projectresultaten	4
4. Projectgrenzen (scope)	5
5. Projectfasering	5
6. Projectorganisatie	6
6.1 Het projectteam	6
6.2 Informatie	9
6.3 Coördinatie	9
7. Kwaliteitsbewaking	12
8. Risicoanalyse	13
9. Planning	14
10. Begroting en middelen	15



1. Achtergronden

Opdrachtgever

De opdrachtgever AanZKOO (Zorg Kwaliteit Ondersteunings Organisatie) ondersteunt zorginstellingen met software die medische data verwerkt. ZKOO is een ICT-dienstverlener in de zorgsector. Ze zijn op meerdere locaties gevestigd, zoals Heerlen, Eindhoven en Utrecht. Er werken ongeveer 85 medewerkers, waarvan 40 in softwareontwikkeling en data-analyse. De klanten van ZKOO zitten met name in Nederland.

De missie: ZKOO ontwikkelt en beheert innovatieve softwareoplossingen die zorginstellingen ondersteunen in het verbeteren van de kwaliteit van zorg. De organisatie streeft naar veilige, gebruiksvriendelijke en toekomstbestendige IT-systemen die zorgprofessionals ontzorgen en ruimte geven voor mensgerichte zorg.

Daarvoor leveren ze op maat gemaakte software voor eerstelijnszorginstellingen zoals:

- Huisartsenpraktijken
- Wijkzorgorganisaties
- GGZ-aanbieders

De belangrijkste functionaliteiten van de software zijn:

- Elektronisch Patiëntendossier (EPD)
- Consultregistratie en dossiervoering
- Behandelplanbeheer
- Rapportage- en analysetools voor zorgkwaliteit
- Aansluitingen op landelijke zorginformatiesystemen (zoals LSP)

Omdat de software van ZKOO medische gegevens verwerkt – zoals diagnoses, behandelplannen en persoonlijke gezondheidsinformatie – voldoet de organisatie aan strenge normen op het gebied van:

- AVG/GDPR-compliance
- NEN 7510 (informatiebeveiliging in de zorg)
- Toegangsbeheer en logging
- Versleuteling van data, zowel in rust als tijdens transport

ZKOO werkt met moderne cloudomgevingen (Microsoft Azure) om schaalbaarheid, beschikbaarheid en beveiliging te garanderen.

Opdrachtnemer

ZKOO heeft vanwege de vele projecten die op dit moment lopen geen capaciteit om een huidig probleem bij een klant snel te kunnen oplossen. Om tijd te besparen en frisse

OPDRACHTEN

nieuwe inzichten te krijgen schakelt ZKOO een extern studententeam van Zuyd Hogeschool van de opleiding HBO-ICT in.

Aanleiding

Bij een klant van ZKOO zijn door een versneld traject naar Microsoft Azure kritieke ICT-componenten onvoldoende beveiligd. Een databeveiligingsbeleid ontbreekt, toegangscontroles zijn niet duidelijk ingericht, en wetgeving zoals de AVG wordt mogelijk geschonden.

2. Doelstelling

ZKOO 3 zal in een tijdsbestek van 10 weken de beveiliging van de cloudomgeving van de klant van ZKOO analyseren, herontwerpen en implementeren.

Dit houdt in:

- De bestaande cloudomgeving (IST) wordt geanalyseerd op zwakke plekken en risico's.
- Een advies en een beveiligingsontwerp (SOLL) wordt opgesteld, waarbij ZKOO inzicht krijgt in beveiligingsmaatregelen conform de AVG.
- Het ontwerp wordt geïmplementeerd en gedemonstreerd binnen Microsoft Azure.

3. Projectresultaten

Fase	Oplevering	Inhoud
Vorbereiding	PvA	Dit document
Fase 1	Advies+ontwerp	Analyse IST, risicoanalyse, IDS-resultaten, advies, ontwerp (SOLL) in de vorm van een adviesrapport en adviesgesprek
Fase 2	Realisatie	Live demo, oplevering portfolio en individuele CGI-toets in Azure

4. Projectgrenzen (scope)

Binnen scope:

- Analyse van bestaande (gesimuleerde) cloudomgeving.
- IDS-monitoring, kwetsbaarheidstests (o.a. SQL-injectie).
- Beveiligingsontwerp m.b.t. netwerksegmentatie, toegangsbeheer, dataclassificatie, logging, en veilig beheer.
- Implementatie binnen Azure-resourcegroup.

Buiten scope:

- Migratie van legacy-systemen.
- Beveiliging van fysieke apparatuur.
- Real-time patiëntgegevens.

5. Projectfasering

Fase 1: Initiatie & Oriëntatie (Week 1-2)

- Analyse van IST-omgeving
- Inrichten monitoring met IDS
- Onderzoek naar kwetsbare software (o.a. SQL-injectie)
- Opstellen risicoanalyse en dataclassificatie
- PvA verder afmaken met hoofdstuk Projectorganisatie

Fase 2: Definitie & Ontwerp (Week 3-5)

- Opstellen van beveiligingsstrategie (SOLL)
- Ontwerpen van veilige netwerktopologie
- Toegangsbeheer en rollenschema's ontwerpen
- Adviesrapport schrijven en adviesgesprek houden

Fase 3: Realisatie & Implementatie (Week 6-9)

- Inrichten beveiligde cloudomgeving in Azure
- Configuratie van firewalls, IDS, VPN's, toegangscontrole
- Testen van infrastructuur en codebeveiliging
- Logging en monitoring activeren

Fase 4: Afronding & Evaluatie (Week 9-10)

- Demo's tijdens lessen
- Oplevering portfolio
- Individuele CGI-toets

6. Projectorganisatie

6.1 Het projectteam

Teamfocus

Onze missie is als team samen te werken aan het verbeteren van gegevensbescherming binnen de Azure-omgeving van ZKOO. Hierbij staan een eerlijke taakverdeling, open communicatie en verantwoordelijkheid voor ieders eigen werk hoog in het vaandel.

De visie die wij als team dragen is het opleveren van een onderbouwd advies en een werkende Proof of Concept. Hiermee laten we zien hoe de onderzochte beveiligingsrisico's beperkt kunnen worden.

Gegevens en afspraken projectleden

Naam	Telefoonnummer	E-mail	Beschikbaarheid
Maiwand Arman	06 - 39 77 03 85	2505493arman@zuyd.nl	Ma t/m Vr: 9:00 - 16:00
Chris Carley	06 - 28 19 16 54	2605402carley@zuyd.nl	Ma t/m Vr: 9:00 - 16:00
Nathalie Koeman	06 - 40 24 90 73	2406365koeman@zuyd.nl	Ma t/m Vr: 9:00 - 16:00
Connor Weerts	06 - 86 65 88 68	2062550weerts@zuyd.nl	Ma t/m Vr: 9:00 - 16:00

Tijdens schooluren zorgen de teamleden dat zij bereikbaar zijn, ook wanneer iemand vanuit huis werkt. Hiervoor gebruiken we communicatiekanalen Whatsapp, Github en Microsoft Teams.

Bij afwezigheid of vertraging meldt het teamlid dit in de Whatsapp-groep. Dit gebeurt zo vroeg mogelijk en uiterlijk 9:00 's ochtends.

Teamrollen en taakverdeling

	Rol 1	Rol 2	Rol 3
<i>Nathalie</i>	Bedrijfsman	Plant	Voorzitter
<i>Chris</i>	Bedrijfsman	Monitor	Brononderzoeker
<i>Connor</i>	Specialist	Monitor	Brononderzoeker
<i>Maiwand</i>	Plant	Voorzitter	Brononderzoeker

Taakomschrijving en bevoegdheden

Projectleider – Nathalie:

Houdt overzicht over de voortgang en taakverdeling, bespreekt knelpunten en stemt afspraken af met de groep. Nathalie leidt ook het overleg en zorgt ervoor dat iedereen aan het woord komt.

Notulist – Maiwand:

Legt besluiten en actiepunten vast. Bij actiepunten noteert hij wie verantwoordelijk is en wanneer de taak afgerond moet zijn. Hij deelt het verslag met de groep.

Planner – Chris:

Houdt de planning bij, bewaakt deadlines en signaleert wanneer taken dreigen uit te lopen. Aanpassingen worden met de groep besproken.

Kwaliteitscontroleur – Connor:

Controleert of producten volledig, duidelijk en volgens de opdrachteisen zijn uitgewerkt. Hij geeft verbeterpunten door aan de verantwoordelijke teamleden.

De taken worden in overleg verdeeld, waarbij rekening wordt gehouden met de hoeveelheid werk, persoonlijke kwaliteiten en leerdoelen. Iedere teamlid is verantwoordelijk voor zijn of haar eigen taken. Als iemand vastloopt, wordt tijdig om hulp gevraagd.

Bij vertrek van een projectlid worden de taken verdeeld over de resterende leden. Indien nodig wordt gestemd over wie de vrijgekomen rol overneemt.

OPDRACHTEN

Sterkte en zwakteanalyse van de teamleden.

Naam	Sterktes	Zwaktes
Chris	- Communicatie. - Werk ethiek. - Organisatie. - Veel technische kennis. - Resultaatgericht.	- Delegeren van werk. - Creativiteit. - Soms te veel gericht op de uitkomsten.
Nathalie	- Verantwoordelijkheid. - Werk ethiek. - Nauwkeurig - Flexibel - Organisatie. - Documentatie.	- Perfectionistisch. - Delegeren van werk. - Onzeker over kennis.
Connor	- Veel technische kennis. - Zelfreflectie. - Doorzettingsvermogen. - Nauwkeurig.	- Communicatie. - Onzeker over de eigen bijdrage. - Planning/structuur.
Maiwand	- Teamwerking. - Flexibel. - Nauwkeurig. - Meedenkend.	- Te zelfkritisch. - Te snel willen werken.

OPDRACHTEN

6.2 Informatie

Binnen het team communiceren wij face-to-face tijdens lessen, via Whatsapp, Github en indien er sprake is van digitaal overleg Microsoft Teams. Projectbestanden worden opgeslagen in Github. Tijdens een wekelijks overleg, gedurende of tussen de lessen in, bespreken wij de voortgang, mogelijke knelpunten en hoe de samenwerking verloopt.

Onze begeleidende docent is Jean-Paul Brands. Nathalie is als projectleider het algemene aanspreekpunt. De student die verantwoordelijk is voor een onderdeel, is ook verantwoordelijk voor het vragen, verwerken en delen van feedback over dat onderdeel. Feedback kan tijdens de lessen gevraagd worden of, indien nodig, buiten de lessen via Teams of e-mail.

	Hoog belang	Laag belang
Hoge invloed	Opdrachtgever Studenten	Docenten
Lage invloed	Medewerkers Cliënten	

Stakeholder	Rol/Belang
Cliënten	Hun persoonlijke gegevens worden opgeslagen. Zij hebben belang bij privacy, beveiliging en correcte verwerking van hun gegevens.
Medewerkers	Voeren cliëntgegevens in, bekijken gegevens en gebruiken het systeem tijdens hun werkzaamheden.
Opdrachtgever	Bepaalt de doelen van het systeem en heeft belang bij een betrouwbaar systeem dat aan de eisen van de organisatie voldoet.
Studenten	Ontwerpen en ontwikkelen het systeem. Hebben belang bij duidelijke requirements, feedback en een haalbare opdracht.
Docenten	Begeleiden de studenten en beoordelen het project.

6.3 Coördinatie

Vergaderen

Overleg vindt plaats tijdens de lessen. Wij verwachten dat er dan voldoende tijd is om de voortgang, taakverdeling en knelpunten te bespreken. Als dit niet voldoende blijkt, plannen wij in overleg een extra vergadering. Ieder projectlid kan hiervoor een verzoek doen. Tijdens de vergaderingen legt Maiwand de notulen vast.

OPDRACHTEN

Besluitvorming

Belangrijke besluiten over het project worden met de hele groep besproken. Eerst proberen wij tot een oplossing te komen waarmee iedereen kan instemmen. Lukt dit niet, dan stemmen wij en geldt de meerderheid. Bij een gelijke uitslag neemt de projectleider na het bespreken van argumenten een besluit en legt de reden vast.

Wanneer teamleden afwezig zijn, worden besluiten genomen door de aanwezige leden en achteraf gedeeld. Het afwezige teamlid kan om heroverweging van dit besluit vragen, wanneer dit met goede argumenten onderbouwd kan worden.

Bij meningsverschillen zoeken we naar een compromis. De projectleider zorgt dat dit besluit duidelijk wordt vastgelegd. Lukt het de projectgroep niet om tot een compromis te komen, vragen wij de docent om begeleiding.

Werkplek en werktijden

Teamleden werken op school en hebben daarnaast de mogelijkheid om vanuit huis te werken. Tijdens schooluren zijn de leden bereikbaar via de afgesproken communicatiekanalen.

Verslaglegging

Indien er geen specifieke richtlijnen zijn voorgeschreven, passen we de volgende standaardisatie toe:

<i>Lettertype</i>	<i>Verdana</i>
<i>Tekenstijl</i>	<i>Standaard</i>
<i>Puntgrootte</i>	<i>12 punten</i>
<i>Koppuntgrootte</i>	<i>12 punten</i>
<i>Opsommingtekens</i>	<i>Zwarte bolletjes</i>
<i>Tabellen</i>	<i>Standaard met zwart omrand</i>
<i>Koptekst</i>	<i>Kop opmaakprofiel</i>
<i>Inspringen</i>	<i>1 tab</i>
<i>Paginanummering</i>	<i>Boven in koptekst</i>
<i>Alinea</i>	<i>1 witregel vrij laten</i>

OPDRACHTEN

Documenten worden tijdens het project opgeslagen en bewerkt in Word (.docx). De definitieve versie wordt als PDF ingeleverd, tenzij de opdracht een ander bestandsformaat voorschrijft.

Archief, uploaden producten en opdrachten

Voor versiebeheer van het project gebruikt de groep Github. Wijzigingen aan de technische uitwerking moeten volgens het samenwerkingscontract door een ander projectlid worden goedgekeurd voordat ze worden samengevoegd.

Projectbestanden worden in herkenbare mappen opgeslagen en bestandsnamen maken duidelijk om welk document het gaat.

Voor oplevering controleert Connor de producten op inhoud, volledigheid en aansluiting op de opdracht. Nathalie controleert of dit wordt uitgevoerd en of de verbeterpunten zijn verwerkt. Vervolgens doet de volledige groep een check en bevestigt dat het product klaar voor oplevering.

Tijdens de wekelijkse sprint review bespreken we of we op schema liggen met alle producten. Hierbij houden we rekening met de volgende oplevermomenten:

- Projectorganisatie: week 2, vrijdag om 15.00 uur.
- Volledig plan van aanpak: week 3, vrijdag om 15.00 uur.
- Analyse, advies en uitvoerbaar PoC-ontwerp: week 5, vrijdag om 15.00 uur.
- Portfolio met bewijs van realisatie: week 9, woensdag om 12.00 uur.
- Individueel CGI: week 10.

Ieder groepslid is zelf verantwoordelijk voor het tijdig inleveren van de opdrachten in diens persoonlijke Moodle omgeving.

Bij een herkansing ondersteunen de overige teamleden het betreffende groepslid waar nodig en wanneer diegene om hulp vraagt. Als meerdere groepsleden een herkansing hebben, kunnen zij samen afspreken en elkaar helpen. Ieder groepslid blijft verantwoordelijk voor de eigen verbetering en oplevering.

OPDRACHTEN

7. Kwaliteitsbewaking

De kwaliteit van de op te leveren diensten en producten worden bewaakt aan de hand van:

- Peer-review op deelopdrachten (Elke twee weken op dinsdag. Weken 2, 4, 6, 8).
- Feedbackrondes met begeleiders (week 3 en week 5).
- Validatie van ontwerp op basis van AVG-checklist.
- Testresultaten van IDS en penetratietesten documenteren.

OPDRACHTEN

8. Risicoanalyse

Het organiseren en uitvoeren van een project kan altijd risico's met zich meebrengen. Onderstaand een overzicht van de belangrijkste risico's en de impact daarvan op het project.

Risico	Kans	Impact	Maatregel
Onduidelijke taakverdeling	Gemiddeld	Hoog	Rollen vooraf bepalen
Technische kennis tekort	Gemiddeld	Middel	Docent raadplegen, documentatie gebruiken
Tijdtekort voor implementatie	Hoog	Hoog	Strakke weekplanning, tijdsbuffers
Problemen met Azure-omgeving	Laag	Hoog	Testomgeving op tijd klaarzetten

9. Planning

Voor dit project wordt in totaal 10 weken tijd ingeruimd. Globaal worden de volgende activiteiten per week uitgevoerd.

Week	Activiteit
Week 1	IST opbouw, start analyse, IDS activeren
Week 2	SQL-injectie tests, dataclassificatie, PvA inleveren
Week 3	Risicoanalyse, advies schrijven
Week 4-5	Ontwerpfase: netwerk, beheer, toegang, advies inleveren
Week 6-7	Implementatie SOLL in Azure
Week 8	Testen, logging controleren, verbeteringen doorvoeren
Week 9	Live demo
Week 10	Individuele CGI-toets

10. Begroting en middelen

Docenten van Zuyd Hogeschool hebben het mogelijk gemaakt om gratis gebruik te maken van software. Onderstaand alle middelen.

- Gebruik van Microsoft Azure for Students (gratis credits)
- Open-source IDS zoals Snort of Suricata
- Microsoft Teams / OneDrive voor communicatie en opslag
- Hardware: laptops van studenten
- Software: Visual Studio Code, OWASP tools, SQLi-testtools